

type of logging, depending on the attack (e.g., focus on logging all the information related to a transaction after it is found to be an attack and ignore extensive logging for other requests). You can also send partial log information (enough to trigger an alarm; you need to see ModSecurity audit log files to go through the entire transaction) through syslog to any existing SIEM (security incident and event management) application.

Virtual patching: This is the most exciting feature of ModSecurity. It configures ModSecurity (by adding/modifying existing rules) so that the attack-utilising vulnerability in an application can be thwarted before it reaches the insecure application, while it is being patched.

This is like fixing problems in an application without touching its code!

However, this activity (done by ModSecurity administrators/security specialists) should not be confused with actually patching an application (which is done by developers). This is at best a stop-gap measure and a long term solution is always to use secure software development life cycle processes.

Attack surface reduction: This term implies that we minimise the avenues for attack by accepting only some types of information and rejecting others. This is done by selectively accepting only some HTTP features (specific request methods, content types, etc) and rejecting others.

Deployment and management considerations

Before you issue the deployment orders for your troops, the following things need to be considered:

1. Do we need ModSecurity? For instance, do we even have any application that is accessible through the Internet?
2. Do we have existing manpower to deal with it, i.e., a Linux sysadmin, dev-ops, security operations centre team, etc? Or do we need to invest in all of these?
3. Infrastructure requirements for deployment need to be planned, usually through a formal change management process, so that any hiccups can be managed.
4. Process requirements need to be identified and addressed. The following questions need to be addressed: Who will own this software? Where will the logs go? Who will review the logs? What shall we do in case of a serious alert? Do we need to update our incident response procedures and probably our disaster recovery procedures?

With proper planning, ModSecurity can be a definite value add-on in the existing security system and for overall business due diligence (not to mention the peace of mind that comes with it). With a dynamic security and legal landscape, it is prudent to have a security system for Web applications as well. 

By: M.S. Sripathi

The author is an ISO 27001 and HIPAA compliant ISMS implementer, who is also keenly aware of more dangerous words like SSAE16, SOX, Do Not Call, ISO 20000-1, ITIL, CoBIT, etc. A CISA (Certified Information Systems Auditor), he can be contacted through sripathi AT gmail DOT com

OSFY Magazine Attractions During 2015-16

MONTH	THEME	BUYERS' GUIDE
March 2015	Open Source Firewall and Network security	SSD for Servers
April 2015	Web Development	Network Switches
May 2015	Virtualisation (containers)	Wireless Routers for SME
June 2015	Open source Databases	PaaS Solution
July 2015	Network Monitoring	MFD Printers for SMEs
August 2015	Mobile App Development	Hosting Solutions
September 2015	Backup and Data Storage	External HDD
October 2015	Mobile App Development	IaaS Solution
November 2015	Cloud Special	Firewall and UTM
December 2015	Open Source on Windows	Online Backup solutions
January 2015	Android Special	Wifi Hotspot Devices
February 2015	Top 10 of Everything	External Storage